3. Non-Functional Requirements (NFRs)

This section specifies the quality attributes and operational constraints that the Collaborative Group Travel Planner system must satisfy. All requirements are stated in measurable, testable terms and are independent of any specific implementation decisions unless otherwise noted. Requirements are classified using the MoSCoW scheme and are traceable to the system architecture described in Section 2.

3.0 NFR Summary Table

Table 3.0 provides a consolidated overview of all non-functional requirements. Detailed specifications follow in Sections 3.1 through 3.5.

Category	Requirement Description	Metric / Measurement	Priority
Performance	Itinerary rendering for up to 20 activities	≤ 3.0 seconds	**High**
Performance	HTTP response time under concurrent load (100 users)	≤ 500 ms	**High**
Performance	In-memory retrieval of cached session/draft data	< 50 ms	**High**
Security	Encryption of sensitive documents at rest	AES-256 or equivalent	**High**
Security	Token-based API authentication with expiry	Access: 1 hr / Refresh: 24 hr	**High**
Security	RBAC enforcement on financial write-access	0 unauthorised write-accesses	**High**
Security	Rate limiting on public endpoints	100 req/min per user	**High**
Reliability	Offline access to confirmed itineraries	100% availability offline	**High**
Reliability	State synchronisation upon connectivity restore	≤ 5 seconds	**High**
Reliability	Automated daily data backup with retention	7-day retention	**Medium**
Usability	Task completion within minimal interaction steps	3–5 clicks/taps	**Medium**
Usability	Graceful error handling — no stack trace exposure	0 stack-trace exposures	**High**
Scalability	Logical separation of core business domains	Modular boundary enforcement	**Medium**
Scalability	Asynchronous execution of non-critical operations	Non-blocking main thread	**Medium**
Maintainability	Audit logging of critical state-changing operations	100% critical ops logged	**Medium**

3.1 Performance & Efficiency

The following requirements define the minimum acceptable performance characteristics of the system under normal and peak operating conditions.

NFR-PER-01: The system shall calculate and render a fully optimised group itinerary, comprising up to twenty (20) scheduled activities, and present the result to the requesting client within three (3.0) seconds of the initiation of the optimisation request.

NFR-PER-02: Under a concurrent load of up to one hundred (100) simultaneously authenticated users, the system shall process and respond to all standard HTTP requests within five hundred (500) milliseconds, measured from the moment the server receives the complete request to the moment the first byte of the response is transmitted.

NFR-PER-03: The system shall retrieve frequently accessed, short-lived data — including, but not limited to, user session states and draft activity records — from an in-memory caching layer within fifty (50) milliseconds, thereby minimising unnecessary read operations on the primary relational database.

3.2 Security & Privacy

The following requirements define the mandatory security controls that the system must enforce to protect user data, prevent unauthorised access, and ensure regulatory alignment.

NFR-SEC-01 — Data Encryption at Rest

NFR-SEC-01: All highly sensitive user documents stored by the system — specifically including, but not limited to, passport scans and national identity documents — shall be encrypted at rest using an industry-standard, symmetric block-cipher algorithm equivalent to or stronger than AES-256. No plaintext copy of such documents shall persist on any storage medium managed by the system.

NFR-SEC-02 — Token-Based Authentication

NFR-SEC-02: All API endpoints that expose protected resources shall require a valid, cryptographically signed bearer token for access. Short-lived access tokens shall expire no later than one (1) hour following issuance. Long-lived refresh tokens, used solely to obtain new access tokens, shall expire no later than twenty-four (24) hours following issuance.

NFR-SEC-03 — Role-Based Access Control

NFR-SEC-03: The system shall enforce Role-Based Access Control (RBAC) on all write-operations targeting financial data and settlement workflows. A request to perform such an operation shall be rejected with an appropriate HTTP 403 Forbidden response unless the authenticated principal possesses a delegated authoritative role (e.g., Trip Organiser or delegated Financial Editor) as recorded in the system's permission registry.

NFR-SEC-04 — Rate Limiting

NFR-SEC-04: The system shall implement per-user rate limiting on all publicly accessible endpoints. No single authenticated or unauthenticated user identity shall be permitted to exceed one hundred (100) requests per minute. Requests that exceed this threshold shall receive an HTTP 429 Too Many Requests response, preventing resource exhaustion and denial-of-service abuse.

3.3 Reliability & Availability

The following requirements define the system's expected behaviour with respect to data availability, fault tolerance, and recovery under adverse network or operational conditions.

NFR-REL-01 — Offline Resilience

NFR-REL-01: The mobile and web client application shall maintain a local persistence layer capable of storing the complete state of all confirmed itinerary items. In the total absence of network connectivity (0% availability), an authenticated user shall be able to view all previously synchronised, confirmed itinerary content without degradation of the presented data.

NFR-REL-02 — State Synchronisation

NFR-REL-02: Upon the restoration of network connectivity following a period of offline operation, the system shall complete the full synchronisation of locally accumulated changes to the authoritative server-side state within five (5) seconds. Conflicts arising from concurrent edits shall be resolved deterministically by applying a Server-is-Truth resolution strategy, whereby the server-side version is treated as canonical and local divergences are resolved accordingly.

NFR-REL-03 — Automated Data Backups

NFR-REL-03: The system shall perform automated, full backups of all persistent data stores on a daily schedule, without requiring manual intervention. Each backup artefact shall be retained in secure storage for a minimum period of seven (7) days, after which it may be purged. The backup mechanism shall be verifiable and shall not impact system availability during execution.

3.4 Usability & User Experience

The following requirements define the interaction efficiency and error communication standards that the system's user interface must satisfy.

NFR-USA-01 — Interaction Efficiency

NFR-USA-01: The user interface shall be designed such that a Trip Member with basic digital literacy is able to complete any core, repetitive task — including, but not limited to, submitting an activity RSVP or recording a shared expense — within a maximum of five (5) discrete user interactions (clicks or taps) from the relevant entry point. No such task shall require fewer than three (3) interactions in order to prevent accidental submissions.

NFR-USA-02 — Graceful Error Communication

NFR-USA-02: In the event of any network failure, server-side processing error, or validation rejection, the system shall present the end-user with a clear, localised, and human-readable error message appropriate to the context of the failure. The system shall, under no circumstances, expose raw technical information — including stack traces, internal exception messages, database query errors, or server-side file paths — to the end-user interface.

3.5 Scalability & Maintainability

The following requirements define the structural and operational quality attributes that ensure the system remains adaptable, auditable, and performant as scope and user-base grow.

NFR-SCA-01 — Modular Domain Separation

NFR-SCA-01: The system architecture shall enforce strict logical separation between each core business domain — including, but not limited to, User Management, Itinerary & Logistics, Financial Settlement, Collaboration, and Document & Safety Management. Inter-domain dependencies shall be expressed through well-defined interfaces or service boundaries, such that the modification or future extraction of any single domain does not necessitate changes to unrelated domains.

NFR-SCA-02 — Asynchronous Non-Critical Operations

NFR-SCA-02: All system operations that are characterised by high latency or that are non-critical to the immediate completion of the originating user request — including, but not limited to, generating automated daily briefing notifications and dispatching outbound email or push alerts — shall be executed asynchronously. Such operations must not block the primary synchronous request-response lifecycle or delay the delivery of the HTTP response to the client.

NFR-SCA-03 — Audit Logging

NFR-SCA-03: The system shall automatically generate a structured, tamper-evident audit log entry for every critical state-changing operation performed within the system. Such operations include, but are not limited to, financial settlement submissions, expense modifications, role-delegation changes, and document access events. Each log entry shall record, at minimum: a precise UTC timestamp, the unique identifier of the authenticated principal performing the action, the type of operation performed, and the identity of the affected resource.